

# Chính sách bảo mật điện toán đám mây

## Metadata

| Trường               | Giá trị                                                                      |
|----------------------|------------------------------------------------------------------------------|
| Mã tài liệu          | APD-IT-022                                                                   |
| Tên công ty          | Công ty TNHH An Phát Digital                                                 |
| Phiên bản            | 1.0                                                                          |
| Ngày hiệu lực        | 2026-05-27                                                                   |
| Ngày rà soát kế tiếp | 2027-05-27                                                                   |
| Chủ sở hữu           | Phòng Công nghệ thông tin                                                    |
| Người phê duyệt      | CISO                                                                         |
| Miền chính sách      | security                                                                     |
| Tài liệu liên quan   | it_security_policy.md, data_privacy_policy.md, incident_response_playbook.md |
| Trạng thái           | Đang hiệu lực                                                                |

### 1. Mục tiêu và nguyên tắc thống nhất

Chính sách bảo mật điện toán đám mây là một phần của bộ quy định công ty cấp doanh nghiệp cho Công ty TNHH An Phát Digital. Tài liệu này không tạo ra hạn mức hoặc thời hạn riêng nếu consistency index đã có quy tắc chuẩn. Mọi đoạn có số ngày, số tiền, vai trò phê duyệt hoặc điều kiện bảo mật phải được hiểu theo bảng quy tắc chuẩn bên dưới.

### 2. Quy tắc chuẩn được kế thừa

Nhóm quy tắc | Mã | Quy định chuẩn không được diễn giải khác

- approval\_matrix | procurement\_standard | < 50.000.000 VND: Trưởng phòng phê duyệt, Tài chính tham vấn, SLA 2 ngày làm việc.
- approval\_matrix | procurement\_quotes | 50.000.000-499.999.999 VND: Giám đốc Khối phê duyệt, Procurement tham vấn, SLA 3 ngày làm việc.
- approval\_matrix | procurement\_large | 500.000.000-1.999.999.999 VND: Giám đốc Khối và CFO phê duyệt, SLA 5 ngày làm việc.
- approval\_matrix | procurement\_strategic | >= 2.000.000.000 VND: CFO và Tổng Giám đốc phê duyệt, SLA 7 ngày làm việc.
- approval\_matrix | revenue\_contract\_large | > 5.000.000.000 VND: CFO và Tổng Giám đốc phê duyệt, Legal và Security tham vấn.
- approval\_matrix | security\_exception | Ngoại lệ bảo mật bất kỳ: CISO phê duyệt, Data Owner tham vấn, SLA 3 ngày làm việc.
- security | password | Mật khẩu tài khoản thông thường tối thiểu 14 ký tự, bật MFA và không tái sử dụng 10 mật khẩu gần nhất.
- security | privileged\_rotation | Tài khoản quản trị đặc quyền phải rà soát hàng tháng và xoay vòng bí mật sau tối đa 90 ngày.
- security | vpn | Truy cập hệ thống nội bộ từ ngoài văn phòng bắt buộc dùng VPN công ty và thiết bị đã đăng ký MDM.
- security | screen\_lock | Thiết bị xử lý dữ liệu mật phải khóa màn hình sau 5 phút không hoạt động.
- security | log\_retention | Log bảo mật mức hệ thống phải lưu tối thiểu 400 ngày.
- records | approval\_evidence | Bảng chứng phê duyệt, workflow, chữ ký điện tử và email chính thức lưu tối thiểu 7 năm.
- records | hr\_records | Hồ sơ nhân sự điện tử lưu 10 năm sau ngày chấm dứt hợp đồng; hồ sơ kỷ luật nghiêm trọng lưu 15 năm.
- records | exception\_register | Ngoại lệ phải có ngày hết hạn, người chịu trách nhiệm, biện pháp giảm thiểu và lưu 3 năm sau ngày đóng.

### 3. Quy định trọng yếu

### 3.1 Cloud\_Security\_Policy Password

Quy định trọng yếu: Mật khẩu tài khoản thông thường tối thiểu 14 ký tự, bật MFA và không tái sử dụng 10 mật khẩu gần nhất.

Đối với chủ đề vai trò chịu trách nhiệm, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đính kèm bằng chứng nguồn và người phê duyệt cuối cùng. Nếu phát hiện nguy cơ rò rỉ dữ liệu hoặc mất tính toàn vẹn của hồ sơ, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề quy trình phê duyệt, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đối chiếu với consistency index trước khi ban hành. Nếu phát hiện nguy cơ thanh toán hoặc cam kết ngoài ngân sách, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề bằng chứng kiểm soát, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện xác nhận ngày hiệu lực và phạm vi áp dụng của chính sách liên quan. Nếu phát hiện nguy cơ mâu thuẫn với tài liệu chính sách đang hiệu lực, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề ngoại lệ, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đánh dấu ngoại lệ theo mã hồ sơ để dễ truy vết. Nếu phát hiện nguy cơ thiếu bằng chứng khi kiểm toán nội bộ yêu cầu, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề báo cáo định kỳ, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện thực hiện rà soát sau triển khai trong kỳ báo cáo gần nhất. Nếu phát hiện nguy cơ ảnh hưởng trải nghiệm khách hàng hoặc SLA vận hành, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề rủi ro và kiểm toán, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện ghi nhận quyết định trong hệ thống workflow chính thức. Nếu phát hiện nguy cơ sai lệch thẩm quyền phê duyệt, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề tham chiếu chéo, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đính kèm bằng chứng nguồn và người phê duyệt cuối cùng. Nếu phát hiện nguy cơ rò rỉ dữ liệu hoặc mất tính toàn vẹn của hồ sơ, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề phạm vi áp dụng, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đối chiếu với consistency index trước khi ban hành. Nếu phát hiện nguy cơ thanh toán hoặc cam kết ngoài ngân sách, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Các bước thực hiện tối thiểu:

1. Xác định chính sách gốc và điều khoản có liên quan.
2. Xác nhận chủ sở hữu quy trình và người phê duyệt cuối cùng.
3. Lưu bằng chứng trong hệ thống chính thức, không dùng file cá nhân làm nguồn duy nhất.

4. Gắn mã điều khoản, mã hồ sơ và ngày hiệu lực vào ticket hoặc workflow.

5. Đóng ngoại lệ đúng hạn hoặc gia hạn bằng phê duyệt mới.

### 3.2 Cloud\_Security\_Policy Privileged\_Rotation

Quy định trọng yếu: Tài khoản quản trị đặc quyền phải rà soát hàng tháng và xoay vòng bí mật sau tối đa 90 ngày.

Đối với chủ đề quy trình phê duyệt, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đối chiếu với consistency index trước khi ban hành. Nếu phát hiện nguy cơ thanh toán hoặc cam kết ngoài ngân sách, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhằm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề bằng chứng kiểm soát, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện xác nhận ngày hiệu lực và phạm vi áp dụng của chính sách liên quan. Nếu phát hiện nguy cơ mâu thuẫn với tài liệu chính sách đang hiệu lực, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhằm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề ngoại lệ, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đánh dấu ngoại lệ theo mã hồ sơ để dễ truy vết. Nếu phát hiện nguy cơ thiếu bằng chứng khi kiểm toán nội bộ yêu cầu, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhằm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề báo cáo định kỳ, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện thực hiện rà soát sau triển khai trong kỳ báo cáo gần nhất. Nếu phát hiện nguy cơ ảnh hưởng trải nghiệm khách hàng hoặc SLA vận hành, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhằm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề rủi ro và kiểm toán, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện ghi nhận quyết định trong hệ thống workflow chính thức. Nếu phát hiện nguy cơ sai lệch thẩm quyền phê duyệt, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhằm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề tham chiếu chéo, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đính kèm bằng chứng nguồn và người phê duyệt cuối cùng. Nếu phát hiện nguy cơ rò rỉ dữ liệu hoặc mất tính toàn vẹn của hồ sơ, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhằm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề phạm vi áp dụng, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đối chiếu với consistency index trước khi ban hành. Nếu phát hiện nguy cơ thanh toán hoặc cam kết ngoài ngân sách, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhằm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề vai trò chịu trách nhiệm, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện xác nhận ngày hiệu lực và phạm vi áp dụng của chính sách liên quan. Nếu phát hiện nguy cơ mâu thuẫn với tài liệu chính sách đang hiệu lực, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhằm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Các bước thực hiện tối thiểu:

1. Xác định chính sách gốc và điều khoản có liên quan.
2. Xác nhận chủ sở hữu quy trình và người phê duyệt cuối cùng.
3. Lưu bằng chứng trong hệ thống chính thức, không dùng file cá nhân làm nguồn duy nhất.
4. Gắn mã điều khoản, mã hồ sơ và ngày hiệu lực vào ticket hoặc workflow.
5. Đóng ngoại lệ đúng hạn hoặc gia hạn bằng phê duyệt mới.

### 3.3 Cloud\_Security\_Policy Vpn

Quy định trọng yếu: Truy cập hệ thống nội bộ từ ngoài văn phòng bắt buộc dùng VPN công ty và thiết bị đã đăng ký MDM.

Đối với chủ đề bằng chứng kiểm soát, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện xác nhận ngày hiệu lực và phạm vi áp dụng của chính sách liên quan. Nếu phát hiện nguy cơ mâu thuẫn với tài liệu chính sách đang hiệu lực, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề ngoại lệ, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đánh dấu ngoại lệ theo mã hồ sơ để dễ truy vết. Nếu phát hiện nguy cơ thiếu bằng chứng khi kiểm toán nội bộ yêu cầu, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề báo cáo định kỳ, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện thực hiện rà soát sau triển khai trong kỳ báo cáo gần nhất. Nếu phát hiện nguy cơ ảnh hưởng trải nghiệm khách hàng hoặc SLA vận hành, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề rủi ro và kiểm toán, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện ghi nhận quyết định trong hệ thống workflow chính thức. Nếu phát hiện nguy cơ sai lệch thẩm quyền phê duyệt, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề tham chiếu chéo, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đính kèm bằng chứng nguồn và người phê duyệt cuối cùng. Nếu phát hiện nguy cơ rò rỉ dữ liệu hoặc mất tính toàn vẹn của hồ sơ, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề phạm vi áp dụng, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đối chiếu với consistency index trước khi ban hành. Nếu phát hiện nguy cơ thanh toán hoặc cam kết ngoài ngân sách, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề vai trò chịu trách nhiệm, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện xác nhận ngày hiệu lực và phạm vi áp dụng của chính sách liên quan. Nếu phát hiện nguy cơ mâu thuẫn với tài liệu chính sách đang hiệu lực, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề quy trình phê duyệt, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đánh dấu ngoại lệ theo mã hồ sơ để dễ truy vết. Nếu phát hiện nguy cơ thiếu bằng chứng khi kiểm toán nội bộ yêu cầu, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

độ sự cố.

Các bước thực hiện tối thiểu:

1. Xác định chính sách gốc và điều khoản có liên quan.
2. Xác nhận chủ sở hữu quy trình và người phê duyệt cuối cùng.
3. Lưu bằng chứng trong hệ thống chính thức, không dùng file cá nhân làm nguồn duy nhất.
4. Gắn mã điều khoản, mã hồ sơ và ngày hiệu lực vào ticket hoặc workflow.
5. Đóng ngoại lệ đúng hạn hoặc gia hạn bằng phê duyệt mới.

### 3.4 Cloud\_Security\_Policy Screen\_Lock

Quy định trọng yếu: Thiết bị xử lý dữ liệu mật phải khóa màn hình sau 5 phút không hoạt động.

Đối với chủ đề ngoại lệ, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đánh dấu ngoại lệ theo mã hồ sơ để dễ truy vết. Nếu phát hiện nguy cơ thiếu bằng chứng khi kiểm toán nội bộ yêu cầu, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề báo cáo định kỳ, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện thực hiện rà soát sau triển khai trong kỳ báo cáo gần nhất. Nếu phát hiện nguy cơ ảnh hưởng trải nghiệm khách hàng hoặc SLA vận hành, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề rủi ro và kiểm toán, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện ghi nhận quyết định trong hệ thống workflow chính thức. Nếu phát hiện nguy cơ sai lệch thẩm quyền phê duyệt, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề tham chiếu chéo, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đính kèm bằng chứng nguồn và người phê duyệt cuối cùng. Nếu phát hiện nguy cơ rò rỉ dữ liệu hoặc mất tính toàn vẹn của hồ sơ, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề phạm vi áp dụng, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đối chiếu với consistency index trước khi ban hành. Nếu phát hiện nguy cơ thanh toán hoặc cam kết ngoài ngân sách, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề vai trò chịu trách nhiệm, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện xác nhận ngày hiệu lực và phạm vi áp dụng của chính sách liên quan. Nếu phát hiện nguy cơ mâu thuẫn với tài liệu chính sách đang hiệu lực, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề quy trình phê duyệt, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đánh dấu ngoại lệ theo mã hồ sơ để dễ truy vết. Nếu phát hiện nguy cơ thiếu bằng chứng khi kiểm toán nội bộ yêu cầu, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề bằng chứng kiểm soát, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện thực hiện rà soát sau triển khai trong kỳ báo cáo gần nhất. Nếu phát hiện nguy cơ ảnh hưởng trải nghiệm khách hàng hoặc SLA vận hành, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Các bước thực hiện tối thiểu:

1. Xác định chính sách gốc và điều khoản có liên quan.
2. Xác nhận chủ sở hữu quy trình và người phê duyệt cuối cùng.
3. Lưu bằng chứng trong hệ thống chính thức, không dùng file cá nhân làm nguồn duy nhất.
4. Gắn mã điều khoản, mã hồ sơ và ngày hiệu lực vào ticket hoặc workflow.
5. Đóng ngoại lệ đúng hạn hoặc gia hạn bằng phê duyệt mới.

### 3.5 Cloud\_Security\_Policy Evidence

Quy định trọng yếu: Bằng chứng phê duyệt, workflow, chữ ký điện tử và email chính thức lưu tối thiểu 7 năm.

Đối với chủ đề báo cáo định kỳ, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện thực hiện rà soát sau triển khai trong kỳ báo cáo gần nhất. Nếu phát hiện nguy cơ ảnh hưởng trải nghiệm khách hàng hoặc SLA vận hành, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề rủi ro và kiểm toán, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện ghi nhận quyết định trong hệ thống workflow chính thức. Nếu phát hiện nguy cơ sai lệch thẩm quyền phê duyệt, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề tham chiếu chéo, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đính kèm bằng chứng nguồn và người phê duyệt cuối cùng. Nếu phát hiện nguy cơ rò rỉ dữ liệu hoặc mất tính toàn vẹn của hồ sơ, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề phạm vi áp dụng, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đối chiếu với consistency index trước khi ban hành. Nếu phát hiện nguy cơ thanh toán hoặc cam kết ngoài ngân sách, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề vai trò chịu trách nhiệm, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện xác nhận ngày hiệu lực và phạm vi áp dụng của chính sách liên quan. Nếu phát hiện nguy cơ mâu thuẫn với tài liệu chính sách đang hiệu lực, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề quy trình phê duyệt, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đánh dấu ngoại lệ theo mã hồ sơ để dễ truy vết. Nếu phát hiện nguy cơ thiếu bằng chứng khi kiểm toán nội bộ yêu cầu, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề bằng chứng kiểm soát, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện thực hiện rà soát sau triển khai trong kỳ báo cáo gần nhất. Nếu phát hiện nguy cơ ảnh hưởng trải nghiệm khách hàng hoặc SLA vận hành,

người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề ngoại lệ, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện ghi nhận quyết định trong hệ thống workflow chính thức. Nếu phát hiện nguy cơ sai lệch thẩm quyền phê duyệt, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Các bước thực hiện tối thiểu:

1. Xác định chính sách gốc và điều khoản có liên quan.
2. Xác nhận chủ sở hữu quy trình và người phê duyệt cuối cùng.
3. Lưu bằng chứng trong hệ thống chính thức, không dùng file cá nhân làm nguồn duy nhất.
4. Gắn mã điều khoản, mã hồ sơ và ngày hiệu lực vào ticket hoặc workflow.
5. Đóng ngoại lệ đúng hạn hoặc gia hạn bằng phê duyệt mới.

### 3.6 Cloud\_Security\_Policy Exception

Quy định trọng yếu: Ngoại lệ phải có ngày hết hạn, người chịu trách nhiệm, biện pháp giảm thiểu và lưu 3 năm sau ngày đóng.

Đối với chủ đề rủi ro và kiểm toán, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện ghi nhận quyết định trong hệ thống workflow chính thức. Nếu phát hiện nguy cơ sai lệch thẩm quyền phê duyệt, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề tham chiếu chéo, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đính kèm bằng chứng nguồn và người phê duyệt cuối cùng. Nếu phát hiện nguy cơ rò rỉ dữ liệu hoặc mất tính toàn vẹn của hồ sơ, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề phạm vi áp dụng, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đối chiếu với consistency index trước khi ban hành. Nếu phát hiện nguy cơ thanh toán hoặc cam kết ngoài ngân sách, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề vai trò chịu trách nhiệm, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện xác nhận ngày hiệu lực và phạm vi áp dụng của chính sách liên quan. Nếu phát hiện nguy cơ mâu thuẫn với tài liệu chính sách đang hiệu lực, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề quy trình phê duyệt, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đánh dấu ngoại lệ theo mã hồ sơ để dễ truy vết. Nếu phát hiện nguy cơ thiếu bằng chứng khi kiểm toán nội bộ yêu cầu, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề bằng chứng kiểm soát, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện thực hiện rà soát sau triển khai trong kỳ báo cáo gần nhất. Nếu phát hiện nguy cơ ảnh hưởng trải nghiệm khách hàng hoặc SLA vận hành, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiều. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch,

loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề ngoại lệ, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện ghi nhận quyết định trong hệ thống workflow chính thức. Nếu phát hiện nguy cơ sai lệch thẩm quyền phê duyệt, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Đối với chủ đề báo cáo định kỳ, tài liệu Chính sách bảo mật điện toán đám mây yêu cầu người thực hiện đính kèm bằng chứng nguồn và người phê duyệt cuối cùng. Nếu phát hiện nguy cơ rò rỉ dữ liệu hoặc mất tính toàn vẹn của hồ sơ, người phụ trách phải tạm dừng bước phê duyệt tiếp theo và tham chiếu consistency index trước khi đưa ra kết luận. Quy định này dùng cùng bộ ngưỡng, thời hạn và vai trò với các chính sách gốc của An Phát Digital để tránh câu trả lời RAG lấy nhầm điều khoản cũ hoặc tài liệu nhiễu. Khi câu hỏi thiếu ngữ cảnh, trợ lý nội bộ phải nêu rõ giả định về cấp bậc, giá trị giao dịch, loại dữ liệu hoặc mức độ sự cố.

Các bước thực hiện tối thiểu:

1. Xác định chính sách gốc và điều khoản có liên quan.
2. Xác nhận chủ sở hữu quy trình và người phê duyệt cuối cùng.
3. Lưu bằng chứng trong hệ thống chính thức, không dùng file cá nhân làm nguồn duy nhất.



- 4. Gắn mã điều khoản, mã hồ sơ và ngày hiệu lực vào ticket hoặc workflow.
- 5. Đóng ngoại lệ đúng hạn hoặc gia hạn bằng phê duyệt mới.

4. Ma trận RACI

| Hoạt động               | Responsible               | Accountable               | Consulted                                    | Informed                          |
|-------------------------|---------------------------|---------------------------|----------------------------------------------|-----------------------------------|
| Soạn thảo và cập nhật   | Phòng Công nghệ thông tin | CISO                      | Pháp chế, Risk, IT Security                  | Các trưởng phòng                  |
| Phê duyệt ngoại lệ      | Chủ sở hữu quy trình      | CISO                      | Tài chính hoặc Privacy Officer nếu liên quan | Kiểm toán nội bộ                  |
| Kiểm tra bằng chứng     | Đội vận hành quy trình    | Phòng Công nghệ thông tin | Kiểm toán nội bộ                             | Ban Điều hành khi có sai lệch lớn |
| Đào tạo và truyền thông | Phòng Công nghệ thông tin | Phòng Công nghệ thông tin | HRBP, Communications                         | Toàn bộ nhân viên liên quan       |

5. Tình huống kiểm thử RAG

5.1 Tình huống vai trò chịu trách nhiệm

Một người dùng hỏi về vai trò chịu trách nhiệm nhưng dùng thuật ngữ gần giống trong data\_privacy\_policy.md. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

5.2 Tình huống quy trình phê duyệt

Một người dùng hỏi về quy trình phê duyệt nhưng dùng thuật ngữ gần giống trong incident\_response\_playbook.md. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

5.3 Tình huống bằng chứng kiểm soát

Một người dùng hỏi về bằng chứng kiểm soát nhưng dùng thuật ngữ gần giống trong it\_security\_policy.md. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

5.4 Tình huống ngoại lệ

Một người dùng hỏi về ngoại lệ nhưng dùng thuật ngữ gần giống trong data\_privacy\_policy.md. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

5.5 Tình huống báo cáo định kỳ

Một người dùng hỏi về báo cáo định kỳ nhưng dùng thuật ngữ gần giống trong incident\_response\_playbook.md. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

5.6 Tình huống rủi ro và kiểm toán

Một người dùng hỏi về rủi ro và kiểm toán nhưng dùng thuật ngữ gần giống trong it\_security\_policy.md. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

5.7 Tình huống tham chiếu chéo

Một người dùng hỏi về tham chiếu chéo nhưng dùng thuật ngữ gần giống trong data\_privacy\_policy.md. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

## 5.8 Tình huống phạm vi áp dụng

Một người dùng hỏi về phạm vi áp dụng nhưng dùng thuật ngữ gần giống trong incident\_response\_playbook.md. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

## 5.9 Tình huống vai trò chịu trách nhiệm

Một người dùng hỏi về vai trò chịu trách nhiệm nhưng dùng thuật ngữ gần giống trong it\_security\_policy.md. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

## 5.10 Tình huống quy trình phê duyệt

Một người dùng hỏi về quy trình phê duyệt nhưng dùng thuật ngữ gần giống trong data\_privacy\_policy.md. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

## 5.11 Tình huống bằng chứng kiểm soát

Một người dùng hỏi về bằng chứng kiểm soát nhưng dùng thuật ngữ gần giống trong incident\_response\_playbook.md. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

## 5.12 Tình huống ngoại lệ

Một người dùng hỏi về ngoại lệ nhưng dùng thuật ngữ gần giống trong it\_security\_policy.md. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

## 5.13 Tình huống báo cáo định kỳ

Một người dùng hỏi về báo cáo định kỳ nhưng dùng thuật ngữ gần giống trong data\_privacy\_policy.md. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

## 5.14 Tình huống rủi ro và kiểm toán

Một người dùng hỏi về rủi ro và kiểm toán nhưng dùng thuật ngữ gần giống trong incident\_response\_playbook.md. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

## 5.15 Tình huống tham chiếu chéo

Một người dùng hỏi về tham chiếu chéo nhưng dùng thuật ngữ gần giống trong it\_security\_policy.md. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

## 5.16 Tình huống phạm vi áp dụng

Một người dùng hỏi về phạm vi áp dụng nhưng dùng thuật ngữ gần giống trong data\_privacy\_policy.md. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

## 5.17 Tình huống vai trò chịu trách nhiệm

Một người dùng hỏi về vai trò chịu trách nhiệm nhưng dùng thuật ngữ gần giống trong incident\_response\_playbook.md. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

## 5.18 Tình huống quy trình phê duyệt

Một người dùng hỏi về quy trình phê duyệt nhưng dùng thuật ngữ gần giống trong `it_security_policy.md`. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

### 5.19 Tình huống bằng chứng kiểm soát

Một người dùng hỏi về bằng chứng kiểm soát nhưng dùng thuật ngữ gần giống trong `data_privacy_policy.md`. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

### 5.20 Tình huống ngoại lệ

Một người dùng hỏi về ngoại lệ nhưng dùng thuật ngữ gần giống trong `incident_response_playbook.md`. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

### 5.21 Tình huống báo cáo định kỳ

Một người dùng hỏi về báo cáo định kỳ nhưng dùng thuật ngữ gần giống trong `it_security_policy.md`. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

### 5.22 Tình huống rủi ro và kiểm toán

Một người dùng hỏi về rủi ro và kiểm toán nhưng dùng thuật ngữ gần giống trong `data_privacy_policy.md`. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

### 5.23 Tình huống tham chiếu chéo

Một người dùng hỏi về tham chiếu chéo nhưng dùng thuật ngữ gần giống trong `incident_response_playbook.md`. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

### 5.24 Tình huống phạm vi áp dụng

Một người dùng hỏi về phạm vi áp dụng nhưng dùng thuật ngữ gần giống trong `it_security_policy.md`. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

### 5.25 Tình huống vai trò chịu trách nhiệm

Một người dùng hỏi về vai trò chịu trách nhiệm nhưng dùng thuật ngữ gần giống trong `data_privacy_policy.md`. Hệ thống RAG phải ưu tiên tài liệu có trạng thái đang hiệu lực, kiểm tra mã APD-IT-022, và nếu câu hỏi liên quan đến ngưỡng chuẩn thì phải dẫn lại consistency index hoặc điều khoản trọng yếu tương ứng. Câu trả lời không được tự tạo ngưỡng mới.

## 6. FAQ

Hỏi 1: Nếu tài liệu này có vẻ khác với một tài liệu khác thì dùng quy định nào?

Ưu tiên tài liệu đang hiệu lực có mã điều khoản cụ thể hơn. Nếu khác biệt liên quan đến số tiền, số ngày, cấp phê duyệt hoặc bảo mật, dùng consistency index làm nguồn chuẩn và gửi yêu cầu làm rõ cho chủ sở hữu chính sách.

Hỏi 2: Nếu tài liệu này có vẻ khác với một tài liệu khác thì dùng quy định nào?

Ưu tiên tài liệu đang hiệu lực có mã điều khoản cụ thể hơn. Nếu khác biệt liên quan đến số tiền, số ngày, cấp phê duyệt hoặc bảo mật, dùng consistency index làm nguồn chuẩn và gửi yêu cầu làm rõ cho chủ sở hữu chính sách.

Hỏi 3: Nếu tài liệu này có vẻ khác với một tài liệu khác thì dùng quy định nào?

Ưu tiên tài liệu đang hiệu lực có mã điều khoản cụ thể hơn. Nếu khác biệt liên quan đến số tiền, số ngày, cấp phê duyệt hoặc bảo mật, dùng consistency index làm nguồn chuẩn và gửi yêu cầu làm rõ cho chủ sở hữu chính sách.

Hỏi 4: Nếu tài liệu này có vẻ khác với một tài liệu khác thì dùng quy định nào?



Hỏi 18: Nếu tài liệu này có vẻ khác với một tài liệu khác thì dùng quy định nào?

Ưu tiên tài liệu đang hiệu lực có mã điều khoản cụ thể hơn. Nếu khác biệt liên quan đến số tiền, số ngày, cấp phê duyệt hoặc bảo mật, dùng consistency index làm nguồn chuẩn và gửi yêu cầu làm rõ cho chủ sở hữu chính sách.

Hỏi 19: Nếu tài liệu này có vẻ khác với một tài liệu khác thì dùng quy định nào?

Ưu tiên tài liệu đang hiệu lực có mã điều khoản cụ thể hơn. Nếu khác biệt liên quan đến số tiền, số ngày, cấp phê duyệt hoặc bảo mật, dùng consistency index làm nguồn chuẩn và gửi yêu cầu làm rõ cho chủ sở hữu chính sách.

Hỏi 20: Nếu tài liệu này có vẻ khác với một tài liệu khác thì dùng quy định nào?

Ưu tiên tài liệu đang hiệu lực có mã điều khoản cụ thể hơn. Nếu khác biệt liên quan đến số tiền, số ngày, cấp phê duyệt hoặc bảo mật, dùng consistency index làm nguồn chuẩn và gửi yêu cầu làm rõ cho chủ sở hữu chính sách.

## 7. Phụ lục

- Phụ lục A: danh sách tài liệu liên quan được dùng để truy xuất chéo.
- Phụ lục B: checklist kiểm tra mâu thuẫn trước khi ban hành.
- Phụ lục C: hướng dẫn gắn metadata policy\_code, effective\_date, owner, domain, source\_anchor khi ingest RAG.